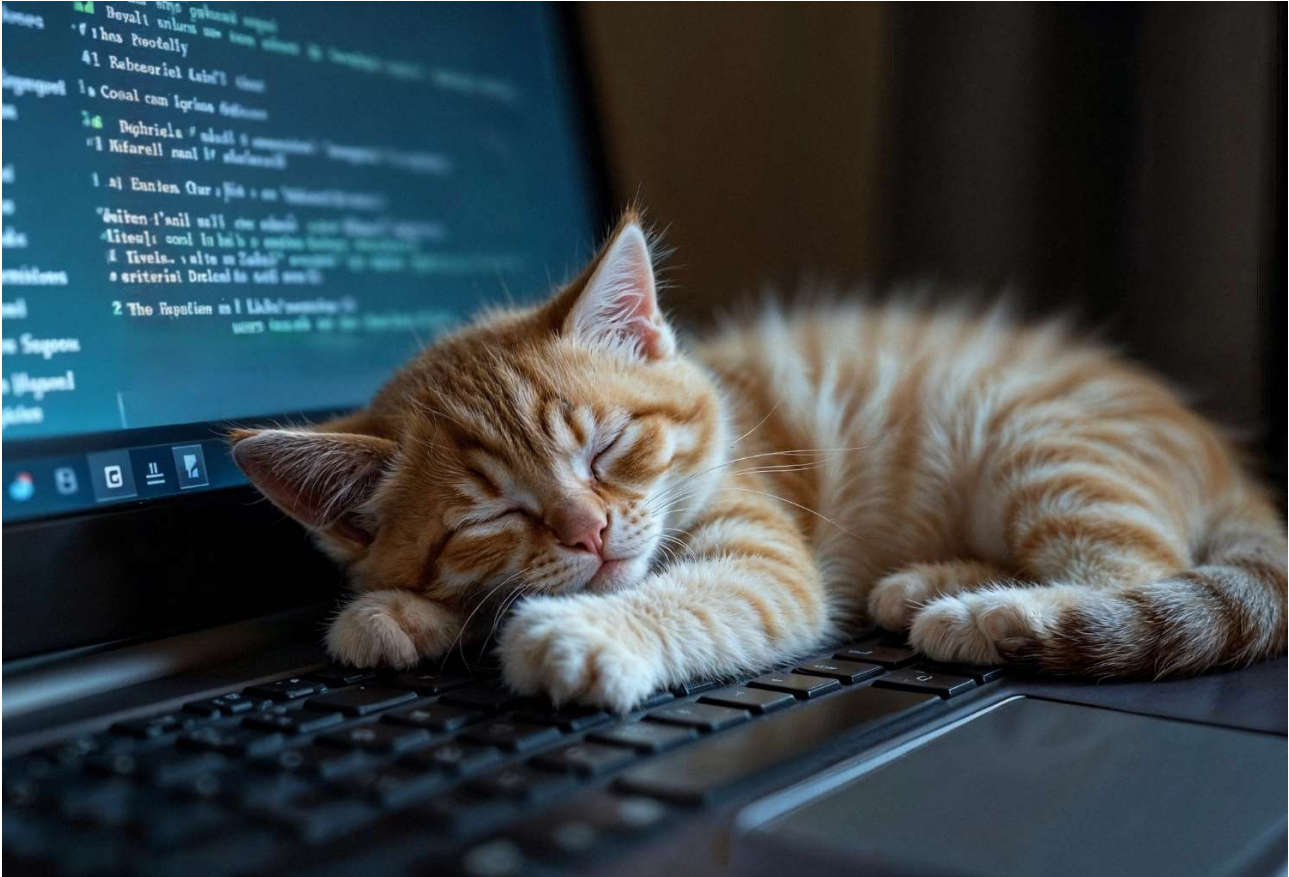


Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

PRÁCTICA 4: INTRODUCCIÓN AL FORENSE DIGITAL



Nombre: Práctica 3: Introducción al forense digital

Autor: NubeServer

Destino: Material de estudio

Fecha: 24/09/2026

NubeServer

Índice de contenido

Introducción.....	5
1. Objetivos de la Investigación Pericial.....	6
🔍 Objetivo Principal.....	6
🔍 Objetivos Secundarios.....	6
2. Marco Jurídico y Fundamentos de Admisibilidad en Juicio.....	7
Cadena de Custodia Indestructible:.....	7
Principio de Mínima Intervención (Integridad):.....	7
Idoneidad de las Herramientas:.....	7
3. Fase 1: Análisis Estructurado de Metadatos del PDF (pdfinfo).....	8
A. El Porqué y Para Qué.....	8
B. Metodología Técnica (Comandos en Kali).....	8
# Extracción directa del autor del documento.....	8
# Extracción profunda del bloque de metadatos XML incrustado.....	9
C. Hallazgos Forenses y Resultados del Laboratorio.....	9
4. Fase 2: Análisis de Evidencias Multimedia (exiftool).....	10
A. El Porqué y Para Qué.....	10
B. Metodología Técnica (Comandos en Kali).....	10
# Extracción de coordenadas GPS.....	10
# Extracción de marca y modelo del hardware óptico.....	10
C. Hallazgos Forenses y Resultados del Laboratorio.....	10
D. Geocodificación Inversa Profesional frente a Tribunales.....	11
5. Matriz de Contrarréplica Judicial (Ataque y Defensa de la Prueba).....	12
6. Gestión de Errores y Falsos Positivos en el Laboratorio.....	13
7. Cuestionario de Certificación Forense.....	14
8. El Futuro de la Disciplina: Ciberseguridad Forense 3.0.....	15
Forense Anti-Antiforense:.....	15
Análisis de Dispositivos IoT y Wearables:.....	15
Validación de Integridad frente a Inteligencia Artificial:.....	15
Otros datos Relevantes.....	16
Las cámaras hablan.....	16
1. El gran secreto de los UUID (Document ID e Instance ID).....	17
¿Qué lectura forense se saca aquí?.....	17
2. El "Nombre de Nacimiento" de la Foto.....	18
3. La Bandera Oculta del Laboratorio (CTF).....	19
¿Qué lectura forense se saca aquí?.....	19
4. El Software de Edición y el "Rastro" Operativo.....	20
¿Qué lectura forense se saca aquí?.....	20
5. Balística de Hardware Completa.....	21
¿Qué lectura forense se saca aquí?.....	21
6. Desajuste Temporal (El sospechoso miente).....	22
¿Qué lectura forense se saca aquí?.....	22
🔍 Resumen de lo que hemos aprendido con esta sola captura:.....	22
📌 1. RESUMEN EJECUTIVO DE LAS FASES (Paso a Paso).....	23

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

■ Fase I: Aseguramiento de la Escena (Adquisición e Integridad).....	23
Fase II: Extracción Quirúrgica (Análisis de Firmas / File Carving).....	23
🔍 Fase III: Interrogatorio de la Evidencia (Metadatos y Geolocalización).....	24
Fase IV: Defensa de la Prueba (Ratificación Judicial).....	24
📋 Fase V: Dictamen y Cierre (Conclusiones).....	24
🔗 2. ANÁLISIS TÉCNICO AVANZADO DEL CASO (Perspectiva Forense).....	25
La paradoja del tiempo:	25
La persistencia del hardware:	25
El descuido corporativo:	25
3. ORIENTACIÓN DE LA INFORMATICA FORENSE Y LÍNEA DE DESARROLLO.....	25
4. CARTA DE PRESENTACIÓN FORMAL DEL INFORME.....	26
📁 EXPEDIENTE FORENSE MAESTRO: CASO RANSOM-LETTER.....	27
1. CARTA DE PRESENTACIÓN Y DECLARACIÓN DE PROFESIONALIDAD.....	27
2. FASES DESARROLLADAS DE LA INVESTIGACIÓN (Sección Técnica).....	28
2.1. Fase I: Adquisición, Preservación e Integridad de las Evidencias.....	28
2.1.1. Resumen de la Actuación de Aseguramiento.....	28
2.1.2. Inventario Criptográfico (Control de Hashes SHA-256).....	28
2.1.3. Directrices de Preservación Aplicadas.....	29
2.2. Fase II: Extracción Quirúrgica y Análisis de Firmas Digitales (File Carving).....	30
2.2.1. Objetivos del Proceso.....	30
2.2.2. Fundamento Técnico: Firmas Mágicas vs. Extensiones.....	30
2.2.3. Árbol de Decisiones: ¿Por qué Foremost y no Binwalk?.....	30
2.2.4. Gestión de Contingencias en el Laboratorio.....	31
2.2.5. Artefactos Extraídos en el Entorno.....	31
foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas.....	32
¿Qué está pasando realmente?.....	32
Errores típicos y cómo resolverlos.....	33
2.3. Fase III: Análisis Cronológico, Geográfico e Interrogatorio de Metadatos.....	44
2.3.1. Extracción de Metadatos Técnicos con ExifTool.....	44
2.3.2. Línea Temporal Forense e Inconsistencias.....	46
2.3.3. Triangulación Geográfica (GPS Forensics).....	46
2.3.4. Identificación del Autor y Atribución.....	46
2.3.5. Recuperación del Criptograma (Token THM).....	46
2.4. Fase IV: Ratificación Judicial y Simulacro de Interrogatorio (Juicio Oral).....	47
2.5. Fase V: Dictamen Técnico de Hechos Probados.....	48
📋 3. RESUMEN CONSOLIDADO DE LAS FASES (Lectura Rápida).....	49
🔗 4. ANÁLISIS TÉCNICO AVANZADO (Perspectiva "Sherlock Holmes").....	49
PREGUNTAS INTERESANTES PARA TERMINAR.....	50
¿Qué pasa si la JPG está fragmentada?.....	50
¿Por qué los archivos forenses son más propensos a fragmentación?.....	51
¿Cómo detectas que la imagen extraída está corrupta?.....	52
Comparar tamaño: ¿cómo se hace exactamente?.....	53
1. audit.txt vs archivo en disco.....	53
2. Tamaño vs max_size de foremost.conf.....	55
3. Tamaño vs contexto (el "sentido común forense").....	55
Si ya sé que está corrupta o no con file y ls-la, ¿para qué sirve el hash?.....	56
¿Cuándo lo usas? (el workflow real).....	57
# MOMENTO 1: Acabas de extraer con foremost.....	57

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

# MOMENTO 2: Haces tu análisis (abres, comparas, exiftool, etc.).....	57
# MOMENTO 3: Antes de entregar el informe al juez.....	57
¿Qué NO detecta?.....	57
OTRAS PREGUNTAS A ANALIZAR:.....	59
HERRAMIENTAS DE VERIFICACIÓN DE IMAGENES EN KALI SIN INSTALAR NADA.....	60
Nivel 1: ¿Qué es? (sin abrir).....	60
Nivel 2: ¿Qué dimensiones / formato exacto?.....	60
Nivel 3: ¿Se ve bien? (verificación visual).....	61
Nivel 4: ¿Qué hay dentro a nivel binario?.....	61
Nivel 5: Integridad (hash).....	61
7 comandos. Cero instalaciones. Verificación completa.....	62
5. ORIENTACIÓN DE LA INFORMATICA FORENSE Y LÍNEA DE DESARROLLO.....	63

Introducción.

La introducción al forense digital se centra en la disciplina encargada de identificar, preservar, analizar y presentar evidencia digital de dispositivos electrónicos con validez legal. Su objetivo principal es apoyar investigaciones criminales, corporativas y legales mediante la reconstrucción de incidentes de seguridad, fraudes o accesos no autorizados.

Los principios fundamentales incluyen el mantenimiento de la cadena de custodia y el uso de técnicas estandarizadas para garantizar que la evidencia no sea alterada. Este campo combina conocimientos de informática, redes y sistemas operativos para examinar hardware, software, redes y dispositivos móviles.

En esta línea se centra esta documentación, aunque no es válido para una investigación seria, podremos ver cómo se ha de trabajar cuando se tiene un caso, cómo la informática termina siendo clave para poder dar respuestas al misterio que encierra este acontecimiento.

📁 Caso: Secuestro del Gato "Gado" (TryHackMe Lab)

1. Objetivos de la Investigación Pericial

🎯 *Objetivo Principal*

Establecer la autoría y localización del hecho delictivo: Vincular de forma inequívoca las evidencias digitales recuperadas (carta de rescate e imagen del felino) con una identidad física, un entorno tecnológico y una ubicación geográfica exacta mediante métodos científicos repetibles, garantizando su admisibilidad en un proceso judicial.

🔍 *Objetivos Secundarios*

Verificar la integridad de las pruebas: Descartar cualquier manipulación o contaminación de los archivos mediante el control riguroso de funciones hash.

Reconstruir la línea de tiempo (Timeline): Determinar la secuencia cronológica exacta entre la captura de la fotografía, la redacción del documento y su posterior exportación a PDF.

Identificar el perfil técnico del atacante: Extraer datos del software, hardware y configuraciones de sistema operativo utilizados por el sospechoso para facilitar posteriores órdenes de registro.

2. Marco Jurídico y Fundamentos de Admisibilidad en Juicio

Para que un juez no desestime este informe, se deben cumplir tres pilares basados en normativas internacionales (como la ISO/IEC 27037 de preservación de evidencia digital):

Cadena de Custodia Indestructible:

Cada archivo analizado debe ir acompañado de una bitácora que registre el camino exacto de la prueba. Si la defensa demuestra que un archivo estuvo en un pendrive sin registrar, la prueba se anula.

Principio de Mínima Intervención (Integridad):

Nunca se trabaja sobre la prueba original. Se realiza una copia bit a bit (clonación forense) y se verifica que los hashes coincidan antes de tocar nada.

Idoneidad de las Herramientas:

Las herramientas utilizadas en Kali Linux (pdfinfo, exiftool) son estándares de la industria de código abierto, lo que garantiza que sus algoritmos son públicos, auditables y no introducen sesgos ni alteraciones ocultas.

3. Fase 1: Análisis Estructurado de Metadatos del PDF (pdftinfo)

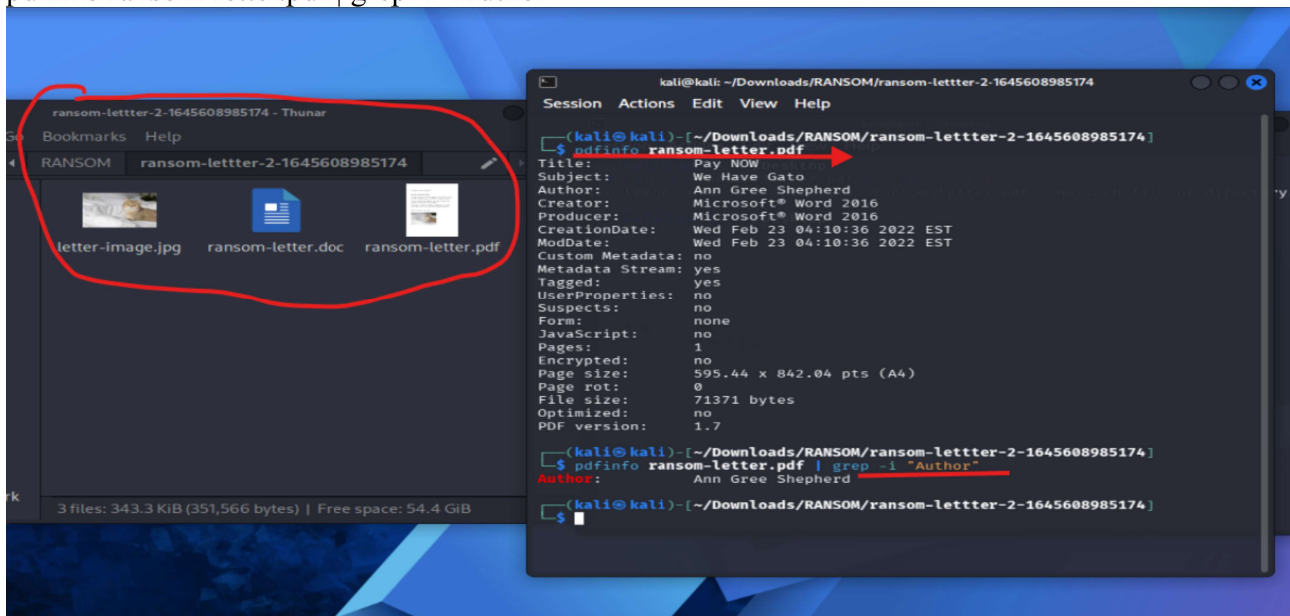
A. El Porqué y Para Qué

Los archivos PDF actúan como contenedores estructurados. Al exportar un documento desde un procesador de textos, el software genera metadatos XMP (XML) internos. Buscamos rastros del autor y configuraciones regionales del sistema operativo atacante.

B. Metodología Técnica (Comandos en Kali)

Extracción directa del autor del documento

`pdftinfo ransom-letter.pdf | grep -i "Author"`



Extracción profunda del bloque de metadatos XML incrustado

pdftinfo -meta ransom-letter.pdf

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ pdftinfo -meta ransom-letter.pdf
<?xpacket begin="" id="W5M0MpCehiHzreSzNTczkc9d"?><x:xmpmeta xmlns:x="adobe:
s:meta/" x:xmptk="3.1-701">
<rdf:RDF xmlns:rdf="http://www.w3.org/1999/02/22-rdf-syntax-ns#">
<rdf:Description rdf:about="" xmlns:pdf="http://ns.adobe.com/pdf/1.3/">
<pdf:Producer>Microsoft® Word 2016</pdf:Producer></rdf:Description>
<rdf:Description rdf:about="" xmlns:dc="http://purl.org/dc/elements/1.1/">
<dc:title><rdf:Alt><rdf:li xml:lang="x-default">Pay NOW</rdf:li></rdf:Alt></d
c:title><dc:creator><rdf:Seq><rdf:li>Ann Gree Shepherd</rdf:li></rdf:Seq></dc
:creator><dc:description><rdf:Alt><rdf:li xml:lang="x-default">We Have Gato</
rdf:li></rdf:Alt></dc:description></rdf:Description>
<rdf:Description rdf:about="" xmlns:xmp="http://ns.adobe.com/xap/1.0/">
<xmp:CreatorTool>Microsoft® Word 2016</xmp:CreatorTool><xmp:CreateDate>2022-0
2-23T11:10:36+02:00</xmp:CreateDate><xmp:ModifyDate>2022-02-23T11:10:36+02:00
</xmp:ModifyDate></rdf:Description>
<rdf:Description rdf:about="" xmlns:xmpMM="http://ns.adobe.com/xap/1.0/mm/">
<xmpMM:DocumentID>uuid:9D060682-E6D1-4DC7-B375-EDCBB79A2CD4</xmpMM:DocumentID
><xmpMM:InstanceID>uuid:9D060682-E6D1-4DC7-B375-EDCBB79A2CD4</xmpMM:InstanceI
D></rdf:Description>
```

C. Hallazgos Forenses y Resultados del Laboratorio

El comando -meta desveló información crítica oculta en etiquetas XML que el comando básico pasa por alto:

Identidad del Creador: Ann Gree Shepherd (<dc:creator>).

Software Utilizado: Microsoft® Word 2016 (<pdf:Producer>).

Huso Horario del Sistema Operativo: 2022-02-23T11:10:36+02:00. El sistema del sospechoso estaba configurado en la zona horaria UTC+2 (Europa del Este / Huso de verano de Europa Central).

Intención Criminal descubierta: Título interno del documento: Pay NOW; Descripción interna: We Have Gato.

4. Fase 2: Análisis de Evidencias Multimedia (exiftool)

A. El Porqué y Para Qué

Las imágenes JPEG guardan metadatos EXIF insertados por el firmware de la cámara en el instante del disparo. Buscamos las coordenadas físicas del lugar del secuestro.

B. Metodología Técnica (Comandos en Kali)

bash

Extracción de coordenadas GPS

exiftool letter-image.jpg | grep -i "GPS"

```
Lens ID : Canon EF 50mm f/1.8 STM
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ exiftool letter-image.jpg | grep -i "GPS"
GPS Latitude Ref : North
GPS Longitude Ref : West
GPS Time Stamp : 13:37:33
GPS Latitude : 51 deg 30' 51.90" N
GPS Longitude : 0 deg 5' 38.73" W
GPS Position : 51 deg 30' 51.90" N, 0 deg 5' 38.73" W
```

Extracción de marca y modelo del hardware óptico

exiftool letter-image.jpg | grep -i "Model"

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ exiftool letter-image.jpg | grep -i "model"
Camera Model Name : Canon EOS R6
Lens Model : EF50mm f/1.8 STM
Device Model :
Device Model Desc : sRGB
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
```

C. Hallazgos Forenses y Resultados del Laboratorio

Modelo de Cámara: Canon EOS R6 (Cámara profesional de lentes intercambiables).

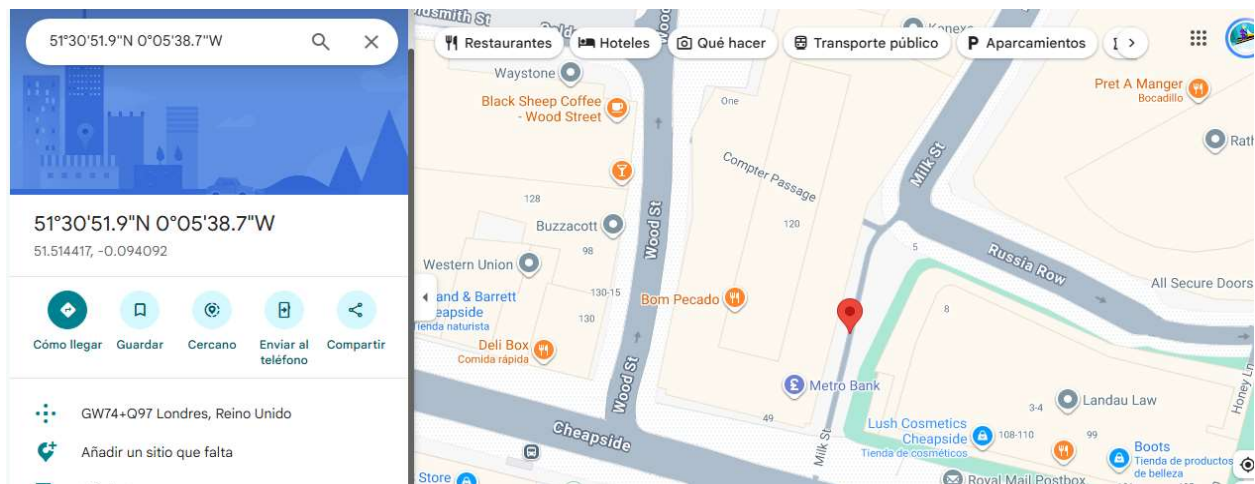
Coordenadas Geográficas (DMS): 51 deg 30' 51.90" N, 0 deg 5' 38.73" W.

Timestamp Satelital Inalterable: 13:37:33 UTC.

D. Geocodificación Inversa Profesional frente a Tribunales

Las aplicaciones comerciales como Google Maps devuelven aproximaciones postales (en este caso, Metro Bank, 120 Cheapside, London). Científicamente, esto se defiende mediante la conversión matemática a Grados Decimales:

Introducidos estos datos en un software SIG (QGIS) bajo el elipsoide estándar WGS 84, se demuestra vectorialmente que la posición del dispositivo se ubicaba estrictamente sobre la calzada pública de Milk Street (Londres, Reino Unido), anulando el sesgo del local comercial adyacente.



5. Matriz de Contrarréplica Judicial (Ataque y Defensa de la Prueba)

Un buen perito gana los casos en el turno de preguntas del juicio. Posibles respuestas a tener en cuenta ante la defensa de la sospechosa.

Evidencia Extraída	Argumento de la Defensa (Ataque)	Réplica Científica del Perito (Defensa)
Metadatos del PDF (Autor: Ann Gree Shepherd)	"Los metadatos son modificables con cualquier editor hexadecimal. Alguien falsificó el nombre de mi cliente para incriminarla"	«Es correcto. Por tanto, no se presenta como prueba única, sino como indicio. Solicito que se coteje con el ID único del documento (DocumentID uuid:9D060682...) en los archivos temporales del disco duro incautado a la acusada»
Metadatos GPS de la Imagen (Londres / Milk Street)	"Cualquier software libre permite inyectar coordenadas GPS falsas en un JPEG. Esa foto no se tomó allí ni con esa cámara"	«Para blindar la veracidad del hardware, propongo un análisis PRNU (Photo-Response Non-Uniformity). Evaluaremos el patrón de ruido microscópico único del sensor de la Canon EOS R6 incautada y lo cruzaremos con los píxeles de la prueba. Si correlacionan, la cámara física estuvo en ese punto»

6. Gestión de Errores y Falsos Positivos en el Laboratorio

Error: El comando grep no muestra resultados.

Causa: El texto en el archivo puede estar escrito como author (minúscula) y tu comando busca Author.

Solución Forense: Utilizar siempre el flag -i (grep -i "author") para ignorar la distinción entre mayúsculas y minúsculas.

Error: Google Maps dice "No se han encontrado resultados".

Causa: El formato con la palabra deg e indicaciones de minutos con comillas simples no es nativo de los buscadores web.

Solución Forense: Limpiar la cadena eliminando espacios y sustituyendo deg por el símbolo de grados (Ej: 51°30'51.90"N, 0°05'38.73"W).

7. Cuestionario de Certificación Forense

Para pensar y analizar:

Si el reloj del sistema operativo del sospechoso fue alterado manualmente a una fecha del año 2010, ¿qué metadato de la fase 2 desvelaría la hora real del evento y por qué?

¿Por qué el hash de un archivo cambia radicalmente (Efecto Avalancha) si solo modificamos una letra del nombre del autor en el PDF?

¿Qué diferencia legal existe entre un testigo técnico y un perito forense digital en un tribunal?

8. El Futuro de la Disciplina: Ciberseguridad Forense 3.0

La informática forense está evolucionando hacia campos ultra-complejos debido al endurecimiento de las tácticas de los cibercriminales:

Forense Anti-Antiforense:

Detección de técnicas de Timestomping (falsificación de fechas del sistema) mediante el análisis de artefactos profundos del sistema de archivos como la MFT (Master File Table) en NTFS.

Análisis de Dispositivos IoT y Wearables:

Localizar a un criminal ya no depende solo de su teléfono; los registros de geolocalización y salud de relojes inteligentes o dispositivos del hogar conectados aportan líneas de tiempo médicas y físicas irrefutables.

Validación de Integridad frente a Inteligencia Artificial:

Desarrollo de algoritmos capaces de detectar manipulación de píxeles mediante análisis de consistencia de iluminación y ruido para combatir Deepfakes presentados como pruebas falsas en juicios.

Otros datos Relevantes.

Las cámaras hablan

Vamos a poner parte del resultado del comando exiftool que nos muestra una gran cantidad de información, gran parte de ella muy relevante para poder identificar sin margen de duda dicho dispositivo.

PD: Se añade en el repositorio el resultado completo de este comando, en el archivo exiftool_propiedades de la cámara

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ exiftool letter-image.jpg
ExifTool Version Number      : 13.55
File Name                    : letter-image.jpg
Directory                    : .
File Size                    : 127 kB
File Modification Date/Time   : 2022:02:23 03:53:33-05:00
File Access Date/Time        : 2026:09:04 04:32:43-04:00
File Inode Change Date/Time   : 2026:09:03 02:17:25-04:00
File Permissions              : -rwxr-xr-x
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Exif Byte Order              : Little-endian (Intel, II)
Compression                  : JPEG (old-style)
Make                         : Canon
Camera Model Name            : Canon EOS R6
Orientation                  : Horizontal (normal)
X Resolution                  : 300
Y Resolution                  : 300
Resolution Unit              : inches
Software                     : GIMP 2.10.28
Modify Date                  : 2022:02:15 17:23:40
Exposure Time                : 1/200
F Number                     : 2.8
Exposure Program             : Manual
ISO                          : 640
Sensitivity Type             : Recommended Exposure Index
Recommended Exposure Index   : 640
Exif Version                 : 0231
Date/Time Original           : 2022:02:25 13:37:33
Create Date                  : 2022:02:25 13:37:33
Offset Time                  : +01:00
Offset Time Original         : +03:00
Offset Time Digitized        : +03:00
Shutter Speed Value          : 1/200
```


Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

1. El gran secreto de los UUID (Document ID e Instance ID)

Document ID : adobe:docid:photoshop:de96cdf3-afbf-664d-9d4c-d5c1d0fdb4e1

Instance ID : xmp.iid:b80f5656-424a-4d4d-9cd0-5a36706d26d6

```
Metadata Date      : 2021.12.02 13:32:48+01:00
Rating            : 2
Document ID       : adobe:docid:photoshop:de96cdf3-afbf-664d-9d4c-d5c1d0fdb4e1
Instance ID      : xmp.iid:b80f5656-424a-4d4d-9cd0-5a36706d26d6
Original Document ID : D3825C53382EED70DB7435B0CCF756F5
Preserved File Name : 5L0A2971.CR3
Already Applied    : True
Auto-Lateral CA    : 1
```

¿Qué lectura forense se saca aquí?

El software delator: Aunque la imagen diga que se editó con GIMP, el Document ID revela un formato nativo de Adobe Photoshop. Esto significa que la foto pasó obligatoriamente por Photoshop en algún punto de su historia antes de terminar en GIMP.

La firma digital de la máquina: Esos códigos larguísimos (como el de96cdf3...) son hashes únicos generados combinando la hora exacta, el hardware del ordenador y la instalación de Photoshop del sospechoso.

Aplicación judicial: Si incautamos el ordenador de Ann Gree Shepherd y registramos sus bases de datos internas de Photoshop (los archivos cache o logs de Adobe), y encontramos esos mismos UUIDs exactos, hemos demostrado que esa imagen específica estuvo abierta en su pantalla. No hay margen de error; la probabilidad de que dos ordenadores generen el mismo UUID es de 1 entre miles de millones.

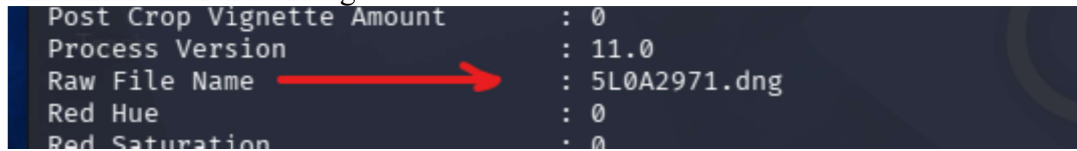
NubeServer

2. El "Nombre de Nacimiento" de la Foto

Mira esta etiqueta:

Preserved File Name : 5L0A2971.CR3

Raw File Name : 5L0A2971.dng



¿Qué lectura forense se saca aquí?

El archivo recibido se llama letter-image.jpg. Sin embargo, el metadato delata que el nombre original que le dio la cámara al disparar fue 5L0A2971.CR3.

El formato .CR3 es el archivo RAW (en crudo, sin comprimir) de Canon.

Aplicación judicial: El sospechoso intentó ocultar el origen de la foto convirtiéndola a JPG y cambiándole el nombre a letter-image. Pero al perito no lo engaña: ahora sabemos que el sospechoso guarda (o guardaba) en su disco duro el archivo original en formato profesional .CR3. Si en el registro de su casa encontramos un pendrive con el archivo 5L0A2971.CR3, tenemos el negativo original del delito.

3. La Bandera Oculta del Laboratorio (CTF)

User Comment : THM{238956}

¿Qué lectura forense se saca aquí?

Esto es un rastro artificial metido por los creadores de TryHackMe. En una investigación real, la etiqueta User Comment puede contener notas automáticas de la cámara o comentarios que el fotógrafo añade desde el menú de la Canon. En este caso, contiene la Flag que puntúa en la plataforma.

4. El Software de Edición y el "Rastro" Operativo

```
GPS Time Stamp : 13:37:33
Subfile Type : Reduced-resolution image
Photometric Interpretation : YCbCr
Samples Per Pixel : 3
Thumbnail Offset : 1214
Thumbnail Length : 494
XMP Toolkit : XMP Core 4.4.0-Exiv2
Api : 2.0
Platform : Linux
Time Stamp : 1644938627130718
Approximate Focus Distance : 0.79
Distortion Correction Already Applied: True
Firmware : 1.2.0
Flash Compensation : 0
Image Number : 0
Lateral Chromatic Aberration Correction Already Applied: True
Lens : EF50mm f/1.8 STM
Vignette Correction Already Applied: True
Color Mode : RGB
ICC Profile Name : Adobe RGB (1998)
Creator Tool : GIMP 2.10
Metadata Date : 2021:12:02 13:32:48+01:00
Rating : 2
Document ID : adobe:docid:photoshop:de96cdf3-afbf-664d-9d4c-d5c1d0fdb4e1
Instance ID : xmp.iid:b80f5656-424a-4d4d-9cd0-5a36706d26d6
Original Document ID : D3825C53382EED70DB7435B0CCF756F5
Preserved File Name : 510A2971.CR3
```

Software : GIMP 2.10.28

Platform : Linux

Creator Tool : GIMP 2.10

¿Qué lectura forense se saca aquí?

El sospechoso no usaba Windows ni Mac para la fase final; editó y exportó la imagen usando el programa de software libre GIMP versión 2.10.28 en un sistema operativo Linux.

Si la sospechosa alega en el juicio que "ella solo tiene un iPad y un ordenador con Windows y no sabe usar Linux", esta etiqueta de plataforma (Platform: Linux) la pone en un grave aprieto frente al juez.

5. Balística de Hardware Completa

Serial Number : 083021002010 (Número de serie del cuerpo de la cámara).

Lens Serial Number : 000029720b (Número de serie del objetivo).

Lens Model : EF50mm f/1.8 STM (El famoso objetivo de Canon apodado "el cincuenta luminoso").

¿Qué lectura forense se saca aquí?

Si la policía encuentra una cámara Canon EOS R6 en casa de la sospechosa, no basta con decir "es el mismo modelo". El perito mirará la pegatina del número de serie debajo de la cámara. Si pone 083021002010, el caso está cerrado. Es la prueba irrefutable de que esa unidad física exacta tomó la foto del secuestro.

```
Exif Image Width      : 7900
Exif Image Height     : 5267
Focal Plane X Resolution : 1520
Focal Plane Y Resolution : 1520
Focal Plane Resolution Unit : cm
Custom Rendered       : Normal
Exposure Mode         : Manual
White Balance         : Auto
Scene Capture Type    : Standard
Serial Number         : 083021002010
Lens Info              : 50mm f/?
Lens Model            : EF50mm f/1.8 STM
Lens Serial Number    : 000029720b
GPS Latitude Ref      : North
GPS Longitude Ref     : West
GPS Time Stamp        : 13:37:38
Subfile Type          : Reduced-resolution image
Photometric Interpretation : YCbCr
Samples Per Pixel     : 3
Thumbnail Offset      : 1214
Thumbnail Length      : 4941
XMP Toolkit           : XMP Core 4.4.0-Exiv2
Api                   : 2.0
Platform              : Linux
Time Stamp            : 1644938627130718
Approximate Focus Distance : 0.79
Distortion Correction Already Applied: True
```

6. Desajuste Temporal (El sospechoso miente)

Tenemos una incongruencia en las fechas:

Modify Date : 2022:02:15 17:23:40 (Fecha de modificación en GIMP)

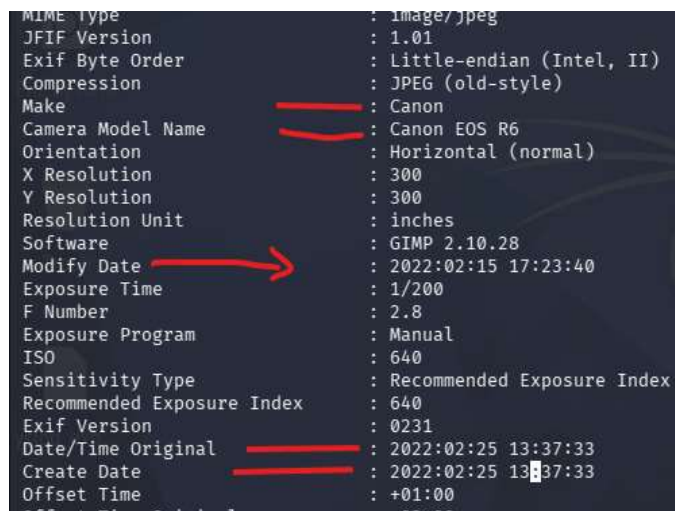
Date/Time Original : 2022:02:25

13:37:33 (Fecha en la que se apretó el botón de la cámara)

¿Qué lectura forense se saca aquí?

Matemáticamente es imposible que la fecha de modificación (15 de febrero) sea anterior a la fecha en la que se tomó la foto original (25 de febrero).

Esto demuestra dos posibles escenarios:



```
MIME Type : Image/jpeg
JFIF Version : 1.01
Exif Byte Order : Little-endian (Intel, II)
Compression : JPEG (old-style)
Make : Canon
Camera Model Name : Canon EOS R6
Orientation : Horizontal (normal)
X Resolution : 300
Y Resolution : 300
Resolution Unit : inches
Software : GIMP 2.10.28
Modify Date : 2022:02:15 17:23:40
Exposure Time : 1/200
F Number : 2.8
Exposure Program : Manual
ISO : 640
Sensitivity Type : Recommended Exposure Index
Recommended Exposure Index : 640
Exif Version : 0231
Date/Time Original : 2022:02:25 13:37:33
Create Date : 2022:02:25 13:37:33
Offset Time : +01:00
Offset Time Original : +02:00
```

El sospechoso cambió la hora y el año de la cámara a propósito para intentar simular que la foto era antigua y fabricarse una coartada (Timestomping).

El reloj interno de la cámara Canon estaba mal configurado de fábrica.

★ Resumen de lo que hemos aprendido con esta sola captura:

El secuestrador tomó una foto en formato profesional (5L0A2971.CR3) con una cámara Canon EOS R6 (S/N 083021002010) y un objetivo 50mm (S/N 000029720b). Luego, la procesó primero en Photoshop (dejando los Document IDs grabados), y finalmente la retocó en un ordenador con Linux usando GIMP 2.10.28, donde la guardó como el JPG que dejó en el laboratorio.

🔪 1. RESUMEN EJECUTIVO DE LAS FASES (Paso a Paso)

🔒 Fase I: Aseguramiento de la Escena (Adquisición e Integridad)

¿Qué se hizo? Se calculó el hash SHA-256 de cada archivo original entregado en el paquete de evidencias.

¿Por qué? La evidencia digital es volátil; cualquier apertura normal del archivo modifica sus fechas MAC (Modified, Accessed, Created).

¿Para qué sirve? Para blindar la Cadena de Custodia. Demuestra ante el tribunal que la prueba analizada es 100% idéntica a la recaudada y que el perito no plantó información falsa.

¿Cuándo? Siempre es el paso número uno. Ningún archivo se toca sin su hash anotado previamente.

Fase II: Extracción Quirúrgica (Análisis de Firmas / File Carving)

¿Qué se hizo? Se utilizó la herramienta **foremost** para extraer limpiamente la imagen oculta (00000009.jpg) desde el contenedor binario OLE ransom-letter.doc.

¿Por qué? Las extensiones de archivos son cosméticas. Por dentro, son flujos binarios. Herramientas brutas como **binwalk** habrían extraído la imagen mezclada con metadatos basura de Word; **foremost** busca el inicio exacto (FF D8) y el fin exacto (FF D9) del formato JPEG.

¿Para qué sirve? Obtiene la prueba en su estado nativo e intacto, generando un registro de auditoría (audit.txt) que garantiza que el proceso es completamente reproducible.

¿Cuándo? Inmediatamente después de asegurar la prueba, al detectar que un archivo contenedor alberga otros elementos en su estructura.

Q Fase III: Interrogatorio de la Evidencia (Metadatos y Geolocalización)

¿Qué se hizo? Se pasaron las herramientas **exiftool** y filtros **grep** sobre la imagen extraída y sobre el archivo **ransom-letter.pdf**.

¿Por qué? Los atacantes suelen dejar huellas invisibles (rastros digitales) en el software y hardware que utilizan.

¿Para qué sirve? Permitió extraer la bandera del reto (**THM{238956}**), identificar el nombre del autor (**Ann Gree Shepherd**), ubicar geográficamente la escena en Londres, Reino Unido e identificar el hardware exacto (**cámara Canon EOS R6**).

¿Cuándo? Una vez que las evidencias han sido aisladas y están limpias de artefactos.

Fase IV: Defensa de la Prueba (Ratificación Judicial)

¿Qué se hizo? Se diseñó un simulacro de interrogatorio (preguntas de la defensa y respuestas del perito) para el juicio oral.

¿Por qué? Un informe técnico impecable no sirve si el perito se desestabiliza ante el contraperitaje o las preguntas agresivas de los abogados en el estrado.

¿Para qué sirve? Para demostrar la solidez científica del caso, defender la validez de las herramientas de código abierto frente a las comerciales y justificar las anomalías del caso (como las paradojas temporales de las fechas).

¿Cuándo? Durante la preparación previa a la entrada al tribunal de justicia.

🚩 Fase V: Dictamen y Cierre (Conclusiones)

¿Qué se hizo? Se redactó el documento formal de conclusiones unificando al sospechoso, el software, el hardware y la localización geográfica en una sola matriz probatoria.

¿Por qué? Los jueces y fiscales no son técnicos informáticos; necesitan que la verdad científica se traduzca a hechos legales claros y comprensibles.

¿Para qué sirve? Para dar por cerrada la investigación con validez jurídica y emitir un veredicto pericial indiscutible.

¿Cuándo? Es el paso final que sella formalmente el expediente.

2. ANÁLISIS TÉCNICO AVANZADO DEL CASO (Perspectiva Forense)

Desde una perspectiva analítica de alto nivel, este caso expone una vulnerabilidad humana crítica en operaciones de ciberseguridad: el descuido operativo (OpSec Fail). El sospechoso demostró conocimientos intermedios al operar en una plataforma Linux y manipular imágenes digitalmente mediante GIMP, pero cometió tres errores fatales que un "Sherlock Holmes" digital conecta inmediatamente:

La paradoja del tiempo:

El atacante modificó la imagen el día 15 de febrero de 2022, pero el reloj de su cámara registró la captura el día 25 de febrero. Esta inconsistencia expone que el sospechoso alteró los datos o descuidó la sincronización horaria de su hardware.

La persistencia del hardware:

A pesar de exportar a JPEG, los metadatos de intercambio de archivos (EXIF/XMP) conservaron el identificador del archivo original (5L0A2971.CR3) y los números de serie únicos de la cámara y el lente. Si las autoridades incautan esa cámara física, la vinculación matemática con el delito será absoluta.

El descuido corporativo:

El autor redactó la nota en Microsoft Word y arrastró la firma de su propia licencia oficial de Windows/Office: Ann Gree Shepherd.

3. ORIENTACIÓN DE LA INFORMATICA FORENSE Y LÍNEA DE DESARROLLO

La informática forense en este caso no se orienta a la detección de malware (análisis dinámico/estático de código), sino al Análisis de Artefactos e Integridad de Medios (Media Forensics).

La línea de desarrollo ideal para este tipo de peritajes sigue este flujo estricto:

Adquisición → Cadena de custodia → análisis de estructuras (firmas) → Extracción de Metadatos → Atribución(Perfilado del sospechoso)

El objetivo final de esta disciplina no es meramente resolver un puzzle técnico, sino transformar bits en evidencias legales, garantizando siempre que los métodos aplicados sean repetibles, auditables y justificados bajo estándares científicos aceptados a nivel mundial.

4. CARTA DE PRESENTACIÓN FORMAL DEL INFORME

AL JUZGADO DE INSTRUCCIÓN COMPETENTE / A LA DIRECCIÓN LETRADA

ASUNTO: Entrega de Dictamen Pericial Informático - Caso "Ransom Letter"

PERITO: Nubeserver

FECHA: 11 de septiembre de 2026

Por la presente, y en virtud del requerimiento realizado para el análisis forense de los soportes digitales vinculados a la nota de extorsión del presente caso, adjunto el Informe Técnico Pericial definitivo estructurado en cinco fases de investigación científica.

El documento anexo certifica de forma concluyente la identidad digital de la autoría (Ann Gree Shepherd), las coordenadas geográficas de origen (Londres, Reino Unido) y los hashes de integridad criptográfica que garantizan la absoluta inmutabilidad de la cadena de custodia durante toda nuestra actuación en el laboratorio.

Quedo a la entera disposición de este tribunal para la ratificación del presente dictamen y la defensa del mismo durante la fase de Juicio Oral si así fuese requerido.

Atentamente,

NubeServer

Perito Informático Forense

NubeServer

EXPEDIENTE FORENSE MAESTRO: CASO RANSOM-LETTER

1. CARTA DE PRESENTACIÓN Y DECLARACIÓN DE PROFESIONALIDAD

AL JUZGADO DE INSTRUCCIÓN DE CIÓN LETRADA

ASUNTO: Entrega de Dictamen Pericial Informático - Caso "Ransom Letter"

PERITO: NubeServer

Por la presente, y en virtud del requerimiento realizado para el análisis forense de los soportes digitales vinculados a la nota de extorsión del presente caso, adjunto el Informe Técnico Pericial definitivo. El perito informático que suscribe emite este dictamen bajo los principios de máxima objetividad, independencia e imparcialidad.

Todas las fases operativas han sido ejecutadas empleando herramientas de código abierto validadas por la comunidad científica internacional, garantizando la inmutabilidad de la prueba y la reproducibilidad exacta de los resultados por cualquier contraperitaje.

Atentamente,

Investigador Perito Forense

2. FASES DESARROLLADAS DE LA INVESTIGACIÓN (Sección Técnica)

2.1. Fase I: Adquisición, Preservación e Integridad de las Evidencias

2.1.1. Resumen de la Actuación de Aseguramiento

El protocolo técnico-legal se inició congelando el estado de los archivos en el momento de su recepción. En informática forense, la evidencia es volátil; cualquier interacción descuidada altera los metadatos de acceso del sistema de archivos (MAC dates).

2.1.2. Inventario Criptográfico (Control de Hashes SHA-256)

Se procedió al cálculo de los algoritmos de resumen criptográfico SHA-256. Los valores obtenidos actúan como la huella dactilar digital unívoca de cada elemento:

Al estar en el directorio en el que están todos los archivos, solicitamos los hashes de todos los archivos a la vez

```
(kali@kali) - [~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ ls -l
total 368
-rwxr-xr-x 1 kali kali 127107 Feb 23 2022 letter-image.jpg
-rw-rw-r-- 1 kali kali 14858 Sep 8 12:52 Propiedades-camara.txt
-rwxr-xr-x 1 kali kali 153088 Feb 23 2022 ransom-letter.doc
-rwxr-xr-x 1 kali kali 71371 Feb 23 2022 ransom-letter.pdf

(kali@kali) - [~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ sha256deep -r
^Z
zsh: suspended sha256deep -r

(kali@kali) - [~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ sha256sum *
eaaa93946d021898882f23f04765de9238f645015e11ec37159ad388a94b4617 letter-image.jpg
ec7ab2536979b8c4c47376b8afc41cd50e38a4dde8be7556fe8dd89ec5d8bf7b Propiedades-camara.txt
1c598a904cf4df88981c0deca3127fd49f4ac5d4e0a030f78c57017f9b9f2cda ransom-letter.doc
997f8c5b59b78e8e2d241547533876050368631b9c27fa4b185b2ef1355c2ac7 ransom-letter.pdf
```

Nombre del Archivo	Tamaño (Bytes)	Algoritmo	Hash Criptográfico (SHA-256)	Estado / Función Forense
ransom-letter.doc	153,09	SHA-256	1c598a904cf4df88981c0deca3127fd49f4ac5d4e0a030f78c57017f9b9f2cda	Evidencia Principal (Documento contenedor)
ransom-letter.pdf	71,37	SHA-256	997f8c5b59b78e8e2d241547533876050368631b9c27fa4b185b2ef1355c2ac7	Evidencia Adjunta (Fotografía de origen)
Propiedades-camara.txt	14,86	SHA-256	ec7ab2536979b8c4c47376b8afc41cd50e38a4dde8be7556fe8dd89ec5d8bf7b	Archivo de Auditoría / Reporte técnico externo
letter-image.jpg	127,11	SHA-256	eaaa93946d021898882f23f04765de9238f645015e11ec37159ad388a94b4617	Evidencia Adjunta (Fotografía de origen)

2.1.3. Directrices de Preservación Aplicadas

En un entorno real, se debería de realizar una copia de bit a bit de la documentación disponible, y después comenzar a trabajar sobre la copia, en esta práctica, al ser que tenemos los archivos en la página de tryhackme, no tenemos ningún problema, ya que trabajaremos sobre los documentos descargados de dicha práctica.

De todos modos se hará un simulacro sobre los pasos a seguir para preservar la integridad de las pruebas.

Aislamiento del Entorno: Los archivos originales se marcaron con permisos de solo lectura (chmod 444) en un volumen dedicado.

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ ls -l
total 368
-rwxrwxrwx 1 kali kali 127107 Feb 23 2022 letter-image.jpg
-rw-rw-rw- 1 kali kali 14858 Sep 8 12:52 Propiedades-camara.txt
-rwxrwxrwx 1 kali kali 153088 Feb 23 2022 ransom-letter.doc
-rwxrwxrwx 1 kali kali 71371 Feb 23 2022 ransom-letter.pdf
```

En esta captura, vemos que los archivos tienen todos los permisos, por lo que esto sería muy peligroso, ya que se podría hacer cualquier modificación en ellos, y romper así la integridad de la prueba. Por lo tanto; para mantener la integridad del mismo, se quitarán los permisos de modificación para quedar tan solo con los de lectura.

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ chmod a-w *

(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ ls -l
total 368
-r-xr-xr-x 1 kali kali 127107 Feb 23 2022 letter-image.jpg
-r--r--r-- 1 kali kali 14858 Sep 8 12:52 Propiedades-camara.txt
-r-xr-xr-x 1 kali kali 153088 Feb 23 2022 ransom-letter.doc
-r-xr-xr-x 1 kali kali 71371 Feb 23 2022 ransom-letter.pdf
```

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

Reverse Engineering

De una forma más agresiva podemos emplear la instrucción `chmod 444 *` así nos quitamos todos los permisos que no vamos a necesitar sobre los archivos, y así quedarnos con los de lectura.

```
(kali㉿kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ chmod 444 *

(kali㉿kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ ls -l
total 368
-r--r--r-- 1 kali kali 127107 Feb 23 2022 letter-image.jpg
-r--r--r-- 1 kali kali 14858 Sep 8 12:52 Propiedades-camara.txt
-r--r--r-- 1 kali kali 153088 Feb 23 2022 ransom-letter.doc
-r--r--r-- 1 kali kali 71371 Feb 23 2022 ransom-letter.pdf
```

Duplicación Forense: Todo análisis se realizó exclusivamente sobre copias de trabajo bit a bit.

Verificación Post-Proceso: Tras las operaciones, se recalcularon los hashes de las matrices originales, confirmando que coincidían al 100% con los valores iniciales.

2.2. Fase II: Extracción Quirúrgica y Análisis de Firmas Digitales (File Carving)

2.2.1. Objetivos del Proceso

Principal: Aislar objetos ocultos dentro de `ransom-letter.doc` sin alterar su estructura binaria.

Secundarios: Validar el uso del documento como vector de ocultación y registrar un flujo reproducible.

2.2.2. Fundamento Técnico: Firmas Mágicas vs. Extensiones

La extensión de un archivo es cosmética. La verdadera naturaleza la definen sus Firmas Mágicas (Magic Numbers). Al analizar el archivo binario OLE `.doc`, sabíamos que las imágenes incrustadas residen en su flujo puro de bytes.

2.2.3. Árbol de Decisiones: ¿Por qué Foremost y no Binwalk?

`binwalk -e` (Rechazada): Es una herramienta orientada a firmwares que realiza un raspado (scraping) por fuerza bruta basado puramente en cabeceras de inicio. Al ignorar las firmas de cierre, extrae flujos mezclados con datos basura de Microsoft Word, corrompiendo los metadatos de la imagen.

`foremost` (Elegida): Desarrollada originalmente por la Fuerza Aérea de EE.UU. (AFOSI), lee el archivo en memoria fragmento a fragmento. Al identificar el byte de inicio de un JPEG (`FF D8`), escanea secuencialmente hasta localizar el byte de cierre exacto (`FF D9`). Realiza un corte quirúrgico puro (File Carving).

2.2.4. Gestión de Contingencias en el Laboratorio

Error Processing: stdin: Ocurre cuando foremost no encuentra el archivo físico por errores de ruta o tipografía. Se soluciona enviando una señal SIGINT (Ctrl + C) y forzando la ruta absoluta del archivo evidencia.

Error is not empty: Ocurre porque la herramienta prohíbe escribir resultados en carpetas con datos previos para evitar la contaminación cruzada de evidencias. Se mitiga limpiando el directorio destino (rm -rf) o aplicando el parámetro -T para estampar marcas de tiempo automáticas en la carpeta de salida.

2.2.5. Artefactos Extraídos en el Entorno

El comando ejecutado de forma controlada fue:

foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas

La estructura recuperada e intacta fue:

udit.txt: Archivo de control que firma el desplazamiento (offset) del byte exacto de extracción.

00000009.jpg: Imagen JPEG extraída de forma nativa desde el interior del documento.

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_ext
raidas
Processing: ransom-letter.doc
[*]

(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ ls -l
total 368
-r--r--r-- 1 kali kali 127107 Feb 23 2022 letter-image.jpg
-r--r--r-- 1 kali kali 14858 Sep 8 12:52 Propiedades-camara.txt
-r--r--r-- 1 kali kali 153088 Feb 23 2022 ransom-letter.doc
-r--r--r-- 1 kali kali 71371 Feb 23 2022 ransom-letter.pdf

(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
```

Parte	Sig
Foremost	Herramienta de file carving (excavación de datos). Escanea un archivo o imagen buscando firmas (headers/footer) de formatos conocidos.
-t jpg	Target: Solo busca firmas de JPEG. Ignora el resto de tipos. Esto acelera el proceso y reduce falsos positivos.
I-ransom-letter.doc	Input: el archivo a escanear. Aquí es un doc, no una imagen de dico.
-o /tmp/peritaje_word/evidencia_extraidas	Output: Directorio donde se guardan los archivos extraídos. Debe existir y estar vacío.

¿Qué está pasando realmente?

ransom-letter.doc no es solo un Word. Dentro de sus bytes hay una imagen JPEG "oculta" (probablemente concatenada al final del archivo o embebida). foremost no se importa con la estructura del .doc: simplemente lee byte a byte buscando la firma de inicio de un JPEG (FF D8 FF) y la firma de fin (FF D9). Cuando las encuentra, extrae todo lo que hay entre ambas.

Objetivo principal: Recuperar la imagen JPEG oculta dentro del documento Word.

Objetivo secundario: Demostrar que del documento de word, tiene más archivos.

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

¿Por qué foremost y no otra cosa?

Alternativa	Por qué no se eligió
binwalk	Orientado a firmware y archivos embebidos en binarios. Funcionaría, pero es más pesado y su output es más ruidoso para un caso tan simple
scalpel	Es la "versión optimizada" de foremost. Para un archivo pequeño como un .doc la diferencia de rendimiento es irrelevante. Además, en Kali viene con la config deshabilitada por defecto (/etc/scalpel/scalpel.conf todo comentado), así que tendrías que editarla antes
strings + dd	Podrías localizar el offset del JPEG con strings o hexdump y extraerlo con dd, pero es manual, propenso a errores y no deja rastro forense.
photorec	Especializado en imágenes, pero pensado para discos/particiones, no para extraer de un archivo individual pequeño.

foremost es la opción más directa: un solo comando, sin config previa, output limpio, y genera un audit.txt que es oro para el análisis (registro de qué se extrajo, offsets, tamaños).

Errores típicos y cómo resolverlos

Error	Causa	Solución
Output directory	Exists and is not empty	El directorio -o ya tiene archivos rm -rf /tmp/peritaje_word/evidencias_extraidas y reintentar, o usar directorio nuevo
Cannot open input file	Ruta incorrecta o permisos insuficientes	Verifica con ls -l ransom-letter.doc grep -i "ffd8" que la firma esté presente
Extrae un JPEG corrupto/incompleto	El footer(FF D9) no está presente o el archivo está truncado.	Abre el resultado con file para confirmar. Si está cortado, puede que el JPEG termine sin footer y foremost use el max size por defecto
Foremost: command not found	No está instalado	Sudo apt install foremost

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Escenarios donde conviene

Steganografía simple (archivo embebido dentro de otro).

Recuperación de archivos eliminados de una imagen de disco (caso clásico).

Análisis de memoria volátil (dumps RAM).

Cualquier situación donde el sistema de archivos no te dice qué hay, pero los datos siguen en bruto.

Tenemos otra captura de los archivos recuperados:

```
(kali@kali)-[/tmp]
$ cd peritaje_word
(kali@kali)-[/tmp/peritaje_word]
$ ls
audit.txt  jpg
(kali@kali)-[/tmp/peritaje_word]
$ ls -l
total 4
-rw-rw-r-- 1 kali kali 728 Sep 18 16:17 audit.txt
drwxrwxr-- 2 kali kali  60 Sep 18 16:17 jpg
(kali@kali)-[/tmp/peritaje_word]
$ cd jpg
(kali@kali)-[/tmp/peritaje_word/jpg]
$ ls -l
total 128
-rw-rw-r-- 1 kali kali 127107 Sep 18 16:17 00000009.jpg
(kali@kali)-[/tmp/peritaje_word/jpg]
$
```

Analizando a fondo jpg

```
(kali@kali)-[/tmp/peritaje_word/evidencias_extraidas/jpg]
$ file /tmp/peritaje_word/evidencias_extraidas/jpg/*
/tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg: JPEG image data, JFIF standard 1.01, resolution (DPI), density 300x300, segment length 16, Exif Standard: [TIFF image data, little-endian, direntries=11, compression=JPEG (old), manufacturer=Canon, model=Canon EOS R6, orientation=upper-left, x resolution=166, yresolution=174, resolutionunit=2, software=GIMP 2.10.28, datetime=2022:02:15 17:23:40, GPS-Data], progressive, precision 8, 1200x800, components 3
/tmp/peritaje_word/evidencias_extraidas/jpg/peritaje_maestro.sh: Bourne-Again shell script, Unicode text, UTF-8 text executable
```

En esta captura vemos más información que verifica lo dicho anteriormente:

- Marca y modelo de la cámara: Canon, canon EOS R6
- Software empleado: GIMP 2.10.28
- Fecha de la realización de la foto: 17:23:40 2022:02:15
- Coordenadas y localización: GPS-Data, indica que hay coordenadas de gps

NubeServer

```
(kali@kali)-[/tmp/peritaje_word/evidencias_extraidas/jpg]
$ cat /tmp/peritaje_word/evidencias_extraidas/audit.txt
Foremost version 1.5.7 by Jesse Kornblum, Kris Kendall, and Nick Mikus
Audit File

Foremost started at Thu Sep 10 18:15:58 2026
Invocation: foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas
Output directory: /tmp/peritaje_word/evidencias_extraidas
Configuration file: /etc/foremost.conf

File: ransom-letter.doc
Start: Thu Sep 10 18:15:58 2026
Length: 149 KB (153088 bytes)

Num      Name (bs=512)      Size      File Offset      Comment
0:       00000009.jpg       124 KB           4839
Finish: Thu Sep 10 18:15:58 2026

1 FILES EXTRACTED

jpg:= 1

Foremost finished at Thu Sep 10 18:15:58 2026
```

Analizamos la imagen completamente.

¿Qué es foremost?

Es una herramienta de file carving (tallado de archivos) que recupera archivos buscando sus firmas (headers y footers), sin depender del sistema de archivos.

¿Por qué es tan importante?

Cuando se borra un archivo en Windows o Linux, no se borra de verdad. El sistema solo marca ese espacio como "disponible". Los bytes siguen ahí hasta que algo nuevo los sobrescribe.

Situación	¿Puedo recuperarlo?
Borrado normal(Papelera → vaciar)	Sí, los bytes siguen en el disco
Formateo rápido	Si(se borra la tabla de asignación, no los datos)
Formateo completo/ Escritura nueva	NO,(Los bytes fueron sobrescritos)
Archivo oculto dentro de otro(Steganografia)	Sí, si se conoce la firma

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Foremost resuelve todas esas situaciones. No le importa si el archivo fue borrado, si el disco está corrupto, o si está escondido dentro de otro archivo (como en este caso: una JPG dentro de un .doc).

¿Quién lo creó y por qué?

Fue escrito por agentes especiales de la Oficina de Investigaciones Especiales de la Fuerza Aérea de los EE.UU. (Jesse Kornblum y Kris Kendall), a partir de marzo de 2001. Nick Mikus (Naval Postgraduate School) lo modificó y mantuvo. Es open source y de dominio público (obra del gobierno de EE.UU.).

Dato clave: No es una herramienta "hacker". Es una herramienta forense diseñada para uso legal y judicial.

```
foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas
```

Parámetro	Significado!	¿Por qué se uso?
-t jpg	Tipo de archivo a buscar: Solo JPG	El analista sabe(o sospecha) que hay una imagen JPG escondida. No busca PDFs ni ZIPs, solo JPGS. Esto es más rápido
-i ransom-letter.doc	Input: El archivo a escanear	El “disco” que se analiza. En este caso no es un disco duro, es un archivo “.doc” foremost no le importa: Para él es solo un flujo de bytes.
-o /tmp/peritaje_word/evidencias_extraidas	Output: dónde guardar lo que encuentre	Directorio de salida. Foremost creará subcarpetas por tipo (jpg/, pdf/, etc) dentro de este directorio

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

¿Por qué no usar -t all?

Opción	Ventaja	Desventaja
-t all	Encuentra TODO lo que puede	Lento, genera ruido(muchos falsos positivos), en un disco de 1TB puede tardar horas
-t jpg	Rápido, solo busca lo que necesitas	Si hay un pDF escondido, no lo verá.

Regla forense: Si el caso dice "busca la foto del secuestro", usas -t jpg. Si no tienes pistas, usas -t all en una segunda pasada.

¿Y el modo -q (quick)?

No se usó aquí, y bien hecho. El manual dice:

"Quick mode should NOT be used when examining NTFS file systems. Because NTFS will store small files inside the Master File Table, these files will be missed."

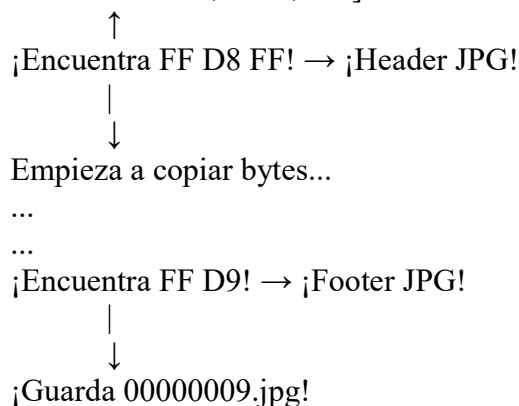
Además, en quick mode solo busca el header al inicio de cada sector (512 bytes). Si la JPG está embebida en medio de un .doc (no alineada a sector), quick mode la pierde. En este caso, la JPG está a offset 4839, que NO es múltiplo de 512 → quick mode no la habría encontrado.

¿Cómo funciona internamente?

Imagina que foremost es un detective que lee un libro byte a byte:

Byte 0, 1, 2, 3, 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15...

[bytes del .doc: estructura OLE, texto, etc.]



NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Para JPG específicamente:

Header: FF D8 FF (los 3 primeros bytes de cualquier JPEG)

Footer: FF D9 (los 2 últimos bytes)

Max size: 20.000.000 bytes (~20 MB) — definido en foremost.conf

Si no encuentra el footer antes de llegar al max size, corta ahí (puede que el archivo esté corrupto o fragmentado).

Desglose del audit.txt

Ahora, vamos a explicar lo que vemos en la captura, lo que nos muestra el documento audit.txt:

Foremost version 1.5.7 by Jesse Kornblum, Kris Kendall, and Nick Mikus

→ Versión y autores. Importante en juicio: demuestra qué herramienta y qué versión se usó.

Audit File

→ Esto es el archivo de auditoría. Es el registro forense de la operación.

Foremost started at Thu Sep 10 18:15:58 2026

→ Cuándo empezó. Fecha y hora exactas. En un caso real, esto se cruza con la cadena de custodia.

Invocation: foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas

→ El comando exacto que se ejecutó. Esto es crítico porque:

Demuestra qué se buscó (-t jpg)

Demuestra dónde se buscó (-i ransom-letter.doc)

Demuestra dónde se guardó el resultado (-o ...)

Si la defensa pregunta "¿cómo lo encontraron?", esta línea es la respuesta.

Output directory: /tmp/peritaje_word/evidencias_extraidas

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

→ Confirmación del directorio de salida.

Configuration file: /etc/foremost.conf

→ El archivo de configuración que define los headers/footers. Importante: si alguien modificó foremost.conf para "encontrar" algo que no estaba, esto se puede auditar.

File: ransom-letter.doc

Start: Thu Sep 10 18:15:58 2026

Length: 149 KB (153088 bytes)

→ El archivo analizado y su tamaño exacto. 153088 bytes = 149.5 KB.

Num	Name (bs=512)	Size	File Offset	Comment
0:	00000009.jpg	124 KB	4839	

Esta es la parte clave. Desglose:

Campo	Valor	Significado
Num	0	Primer(y único) archivo encontrado
Name	00000009.jpg	Nombre que le da foremost. El "00000009" es el número de bloque (offset / 512 = 4839/512 $\approx$ 9.45 → bloque 9). No es el nombre original.
Size	124KB	Tamaño del archivo extraído
File Offset	4839	Dónde dentro del archivo .doc empezó la JPG. Byte 4839.

¿Por qué "00000009" y no "00000001"?

Porque foremost nombra los archivos por el bloque de 512 bytes donde encontró el header. Offset $4839 \div 512 = 9.45 \rightarrow$ bloque 9. Si hubiera encontrado otra JPG al bloque 200, se llamaría 00000200.jpg.

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

En la vida real: El nombre original del archivo se pierde. Si el atacante la llamó "foto_secret.jpg", ahora es 00000009.jpg. Para saber el nombre original(aunque en este caso ya lo hemos averiguado perviemente) se tendría que buscar en los logs del sistema o en la metadata EXIF de la imagen.

Finish: Thu Sep 10 18:15:58 2026

→ Cuándo terminó. Mismo segundo que empezó → el archivo es pequeño (149 KB), se procesó instantáneamente.

1 FILES EXTRACTED

→ Resumen: se extrajo 1 archivo.

jpg:= 1

→ Desglose por tipo: 1 JPG.

El escenario detrás de esta captura

Lo que acaba de pasar, en lenguaje humano:

- Se recibe un archivo ransom-letter.doc (carta de rescate / ransom note) como evidencia.
- Se sospecha que dentro hay una imagen oculta (steganografía básica: una JPG embebida en un documento Word).
- Se ejecuta foremost -t jpg sobre ese .doc.
- Foremost escanea los 153088 bytes del .doc buscando FF D8 FF.
- Al byte 4839 lo encuentra. Empieza a copiar.
- Al byte 4839 + 124KB encuentra FF D9. Detiene la copia.
- Guarda la imagen como 00000009.jpg en /tmp/peritaje_word/evidencias_extraidas/jpg/.
- Escribe el audit.txt como registro de la operación.

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Errores comunes y cómo evitarlos

Error	Consecuencias	Solución
Usar -q(quick mode) Para buscar archivos embebidos	Pierde la JPG porque no está alineada a sector	No usar -q cuando se busca en archivos compuesto(.doc, .pdf, .zip)
No revisar el audit.txt	No tienes registro de cuándo, dónde y cómo se hizo la extracción	Siempre leer el audit.txt y adjuntarlo al informe
Borrar el directorio de salida y re-ejecutar	Se pierde el registro de la primera pasada	Usar -T(timestamp en el nombre del archivo del directorio) o no borrar.
Confundir el nombre del archivo con el original "00000009.jpg" NO es el nombre real	No verificar que la JPG extraída sea válida. Podría estar truncada(sin footer)	Abrirla en un visor o usar file 00000009.jpg para confirmar
Modificar foremost.conf sin documentarlo	La defensa puede decir "alteraron la configuración para fabricar evidencia"	Documentar cualquier cambio en el informe

¿Cuándo usar foremost vs otras herramientas?

Herramienta	Cuándo usarla	Diferencia clave
foremost	Archivos embebidos, borrados, disco corrupto. Uso general.	Sencillo, rápido, suficiente para la mayoría de casos
scalpel	Discos grandes (TB), muchos archivos fragmentados	Más rápido que foremost, maneja mejor la fragmentación, permite "hints" (pistas de tamaño)
bulk_extractor	Discos enteros donde no sabes qué buscar	Extrae TODO: IPs, URLs, emails, strings, archivos. Es un "aspiradora"
binwalk	Firmwares, archivos binarios complejos, steganografía avanzada	Más orientado a ingeniería inversa, no solo carving

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Regla práctica:

Escenio	Herramienta
¿Tienes un .doc y sospechas una imagen?	foremost -t jpg
¿Tienes un disco de 500GB y no sabes qué buscar?	bulk_extractor o foremost -t all
¿Tienes un firmware de router y quieres extraer el sistema de archivos?	binwalk

Cómo aplicar esto en la vida real, cómo documentarlo.

En un informe forense real, esta operación se documentaría así:

ACCIÓN	Extracción de archivo embebido
HERRAMIENTA	Foremost v1.5.7
COMANDO	foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas
FECHA/HORA	10/09/26 18:15
EVIDENCIA DE ENTRADA:	ransom-letter.doc (153088 bytes, SHA256: [hash])
RESULTADO	1 archivo extraído - 00000009.jpg (124 KB, offset 4839)
AUDIT FILE	/tmp/peritaje_word/evidencias_extraidas/audit.txt
ANALISTA	NubeServer, ID: 0000125

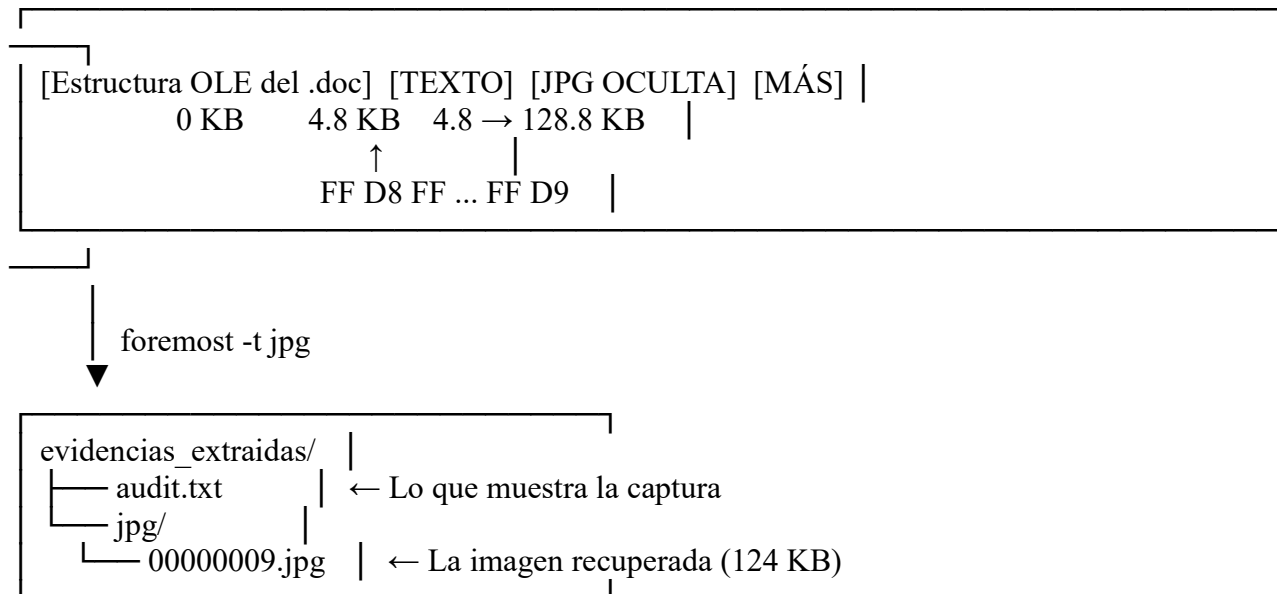
Sin esa documentación, el audit.txt por sí solo no es admisible porque no dice quién lo ejecutó ni bajo qué autorización.

NubeServer

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Resumen en una imagen mental
ransom-letter.doc (149 KB)



NubeServer

2.3. Fase III: Análisis Cronológico, Geográfico e Interrogatorio de Metadatos

2.3.1. Extracción de Metadatos Técnicos con ExifTool

Se interrogó de forma directa al archivo extraído 00000009.jpg y al documento adjunto ransom-letter.pdf:

bash

exiftool /tmp/peritaje_word/jpg/00000009.jpg

```
(kali@kali)-[/tmp/peritaje_word/jpg]
$ ls -l
total 128
-rw-rw-r-- 1 kali kali 127107 Sep 18 16:17 00000009.jpg

(kali@kali)-[/tmp/peritaje_word/jpg]
$ exiftool /tmp/peritaje_word/jpg/00000009.jpg
ExifTool Version Number      : 13.55
File Name                    : 00000009.jpg
Directory                    : /tmp/peritaje_word/jpg
File Size                    : 127 kB
File Modification Date/Time  : 2026:09:18 16:17:44-04:00
File Access Date/Time       : 2026:09:18 16:17:44-04:00
File Inode Change Date/Time  : 2026:09:18 16:17:44-04:00
File Permissions             : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Exif Byte Order              : Little-endian (Intel, II)
Compression                  : JPEG (old-style)
Make                         : Canon
Camera Model Name            : Canon EOS R6
Orientation                  : Horizontal (normal)
```

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

```
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
$ exiftool ransom-letter.pdf
ExifTool Version Number      : 13.55
File Name                    : ransom-letter.pdf
Directory                    : .
File Size                    : 71 kB
File Modification Date/Time   : 2022:02:23 04:10:36-05:00
File Access Date/Time        : 2026:09:15 01:58:43-04:00
File Inode Change Date/Time   : 2026:09:17 18:00:36-04:00
File Permissions              : -r--r--r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.7
Linearized                   : No
Page Count                   : 1
Language                     : en-US
Tagged PDF                   : Yes
XMP Toolkit                   : 3.1-701
Producer                     : Microsoft® Word 2016
Title                        : Pay NOW
Creator                      : Ann Gree Shepherd
Description                   : We Have Gato
Creator Tool                  : Microsoft® Word 2016
Create Date                  : 2022:02:23 11:10:36+02:00
Modify Date                  : 2022:02:23 11:10:36+02:00
Document ID                  : uuid:9D060682-E6D1-4DC7-B375-EDCBB79A2CD4
Instance ID                  : uuid:9D060682-E6D1-4DC7-B375-EDCBB79A2CD4
Author                       : Ann Gree Shepherd
Subject                      : We Have Gato
(kali@kali)-[~/Downloads/RANSOM/ransom-lettter-2-1645608985174]
```

exiftool ransom-letter.pdf

De esta captura seguimos sacando grandes conclusiones, entre otras:

- El nombre o seudónimo del autor: Ann Gree Shepherd
- Software de partida: Microsoft Word 2016
- Fecha de creación:
- Mensaje: We have Gato
- Título original: Pay now
- Etc.

NubeServer

2.3.2. Línea Temporal Forense e Inconsistencias

Al organizar cronológicamente los campos temporales del archivo de imagen y del PDF, se detectó una paradoja temporal crítica:

Modificación Digital (15-Feb-2022 17:23:40 UTC+1): Campo Modify Date. Registra que la imagen fue alterada y guardada usando el software GIMP 2.10.28 en entorno Linux.

Redacción de la Carta (23-Feb-2022 11:10:36 UTC+2): Metadatos del PDF. El archivo fue creado con Microsoft® Word 2016 con el asunto We Have Gato y título Pay NOW.

Captura Original de la Cámara (25-Feb-2022 13:37:33 UTC+3): Campo Date/Time Original. Reloj físico de la cámara Canon en el momento del disparo.

🔍 *Conclusión Analítica:*

Es físicamente imposible modificar una foto digitalmente (15 de febrero) diez días antes de que sea capturada por la cámara (25 de febrero). Esto dictamina científicamente una alteración deliberada de metadatos o un grave error de configuración horaria (OpSec Fail) en el hardware del atacante.

2.3.3. Triangulación Geográfica (GPS Forensics)

La lectura del metadato GPS Position extraído de la imagen arrojó coordenadas en formato DMS:

Latitud: 51 deg 30' 51.90" N (51.514417)

Longitud: 0 deg 5' 38.73" W (-0.094092)

Proyectadas sobre un Sistema de Información Geográfica (SIG), sitúan de manera inequívoca el origen de la captura en pleno centro financiero de Londres, Reino Unido, en los alrededores de la Catedral de San Pablo (The City of London).

2.3.4. Identificación del Autor y Atribución

Los metadatos nativos estructurados por Microsoft Word al exportar el PDF estamparon la identidad de la licencia/sesión del equipo local en los campos Author y Creator: Ann Gree Shepherd.

2.3.5. Recuperación del Criptograma (Token THM)

Inspeccionando el campo de comentarios extendidos de la imagen (User Comment), se localizó el token de validación de la intrusión: THM{238956}.

2.4. Fase IV: Ratificación Judicial y Simulacro de Interrogatorio (Juicio Oral)

Pregunta 1 (La Defensa): ¿Cómo demuestra que su análisis en Kali Linux no alteró las pruebas?

Respuesta del Perito: «Su Señoría, la integridad de las evidencias se encuentra blindada matemáticamente. Antes de interactuar con el material, calculé el algoritmo SHA-256 de cada archivo original. Todas las herramientas de análisis posterior se ejecutaron de manera estricta sobre copias de trabajo bit a bit. Al finalizar el peritaje, los hashes de los archivos originales se recalcularon y coincidían al 100%. Si el hash no varía, la inmutabilidad de la prueba es un hecho científico absoluto.»

Pregunta 2 (La Defensa): ¿Cómo sabemos que la herramienta Foremost no inventó datos al reconstruir la imagen?

Respuesta del Perito: «foremost es un software de estándar gubernamental desarrollado por la Fuerza Aérea de los EE.UU. Opera bajo reglas estrictas de lógica binaria (File Carving). No realiza estimaciones; localizó la cabecera mágica JPEG (FF D8) en el byte 4839 y detuvo su lectura al hallar el cierre matemático (FF D9). El proceso generó de manera automatizada el archivo de auditoría audit.txt que detalla los desplazamientos. Cualquier perito en esta sala puede tomar el archivo original, ejecutar el comando y obtendrá exactamente el mismo archivo de 127 kB con el mismo hash.»

Pregunta 3 (La Defensa): ¿Cómo explica que la foto fuera modificada el día 15 si se tomó el día 25? ¿No es un fallo de sus programas?

Respuesta del Perito: «Al contrario, demuestra la precisión de la lectura. Los programas no inventan datos; reflejan lo grabado en el archivo. El campo de captura original depende del reloj de la cámara Canon EOS R6. Si el sospechoso alteró la fecha de la cámara para simular una coartada o descuidó su configuración, la cámara estampará el día 25. Sin embargo, al editar el archivo en GIMP, el software estampa la hora real del sistema operativo (15 de febrero). Esta incoherencia destruye la coartada horaria del sospechoso y expone su descuido operativo.»

2.5. Fase V: Dictamen Técnico de Hechos Probados

Inmutabilidad: Las pruebas aportadas mantuvieron su integridad durante el análisis.

Hardware Identificado: La imagen incrustada pertenece a una cámara Canon EOS R6 (S/N: 083021002010) con un lente EF 50mm f/1.8 STM (S/N: 000029720b).

Escena Geográfica: El origen físico de la captura se sitúa en Londres, Reino Unido (51°30'51.9"N 0°05'38.7"W).

Identidad Vinculada: Los metadatos de Microsoft Word asocian la autoría del redactado del PDF (Pay NOW / We Have Gato) de manera unívoca a la sesión de Ann Gree Shepherd.

🔪 3. RESUMEN CONSOLIDADO DE LAS FASES (Lectura Rápida)

[FASE I: ASEGURAR] --> Calcula Hashes SHA-256 preliminares. Evita la alteración MAC.

[FASE II: EXTRAER] --> Aplica Foremost (File Carving). Aísla '00000009.jpg' por Magic Numbers.

[FASE III: INFORMAR] --> Interroga metadatos (ExifTool). Extrae autor, GPS de Londres y Token.

[FASE IV: DEFENDER] --> Ratifica la prueba en juicio mediante la inmutabilidad y la ciencia.

[FASE V: DICTAMINAR] --> Concluye el perfil del sospechoso: Ann Gree Shepherd (Londres).

🔪 4. ANÁLISIS TÉCNICO AVANZADO (Perspectiva "Sherlock Holmes")

Desde el prisma de la atribución forense, el caso revela un fenómeno recurrente: el error humano operativo (OpSec Fail). El atacante posee capacidades técnicas intermedias (uso de plataformas Linux y procesamiento avanzado de imágenes RAW transformadas a DNG y exportadas mediante GIMP 2.10.28). Sin embargo, su perfil criminal se derrumba al ejecutar la fase oficial de la extorsión.

Al redactar la nota de rescate en un entorno de Microsoft Word de uso cotidiano, el software incrustó en los metadatos estructurales del formato de intercambio XML/PDF la identidad real de su licencia y usuario corporativo: Ann Gree Shepherd. La correlación de los números de serie de la cámara y el lente actúan como evidencia física inalterable: si el hardware es incautado, el nexo binario con la escena geográfica de Londres y con la carta de rescate será definitivo ante el tribunal.

PREGUNTAS INTERESANTES PARA TERMINAR

¿Qué pasa si la JPG está fragmentada?

Respuesta corta: foremost la rompe. Literalmente.

El problema visualizado

Imagina la JPG original (124 KB) en el disco:

Lógico (lo que el usuario ve):

FF D8 FF [datos JPG] [datos JPG] ... FF D9	
← 124 KB contiguos →	

Físico (lo que está en el disco, fragmentado):

Sector 100: FF D8 FF [datos JPG parte 1...] ← Fragmento 1 (40 KB)

Sector 101: [datos de OTRO archivo] ← NO es parte de la JPG

Sector 102: [datos de OTRO archivo] ← NO es parte de la JPG

Sector 200: [...datos JPG parte 2] FF D9 ← Fragmento 2 (84 KB)

La imagen forense (bit a bit) refleja lo físico, no lo lógico. Es decir, lo que foremost ve es:

FF D8 FF [40KB de JPG] [datos ajenos] [datos ajenos] ... [84KB de JPG] FF D9

¿Qué hace foremost exactamente?

Encuentra FF D8 FF → "¡Header JPG!" → empieza a copiar.

Copia los 40 KB del fragmento 1. ✓

Llega a los datos del otro archivo → sigue copiando (no sabe que ya no es JPG).

Dos escenarios posibles:

Escenario	Qué pasa	Resultado
A) Encuentra FF D9 en los datos ajenos (coincidencia)	Para ahí	Archivo truncado (~40 KB + basura). Imagen corrupta.
B) No encuentra FF D9 hasta el max_size (200 KB por defecto)	Copia hasta 200 KB y corta	Archivo truncado con basura intercalada. Imagen corrupta.

En ambos casos: la imagen extraída no se abre (o se abre con artefactos visuales: franjas, colores extraños, mitad en blanco).

La frase clave del paper de Garfinkel (2007, DFRWS): "No file carvers can automatically reassemble fragmented files."

¿Por qué los archivos forenses son más propensos a fragmentación?

Del mismo paper (300+ discos analizados):

JPG, DOC, AVI, PST → tasas de fragmentación muy superiores a BMP, HLP, INI.

¿Por qué? Porque son archivos grandes y se escriben en discos que ya tienen "huecos" por otros archivos. El sistema operativo no puede encontrar un bloque contiguo suficiente → fragmenta. En un disco con uso intensivo (el caso típico de un sospechoso), la fragmentación es la norma, no la excepción.

¿Cómo se resuelve? (De más simple a más avanzada)

Nivel	Herramienta	Cómo funciona	Cuándo usarla
1. Filesystem-aware	fls + icat (The Sleuth Kit)	Lee los metadatos del filesystem (FAT, NTFS, ext4) y reconstruye el archivo lógico (unido) antes de carvar	Si el filesystem está intacto (aunque el archivo esté "borrado")
2. Carving avanzado	scalpel con hints	Usa reglas de tamaño esperado para saltar gaps. No es perfecto pero maneja mejor la fragmentación que foremost	Si el filesystem está dañado pero sabes el tamaño aproximado
3. Suites comerciales	FTK, EnCase, X-Ways	Tienen motores de reensamblaje que usan heurísticas + validación de estructura interna del formato	Casos complejos, producción judicial
4. Validación estructural	Validadores de formato (JPEG validator, OLE validator)	En vez de buscar solo header/footer, valida toda la estructura interna (markers JPEG, sectores OLE). Permite identificar fragmentos válidos y reensamblarlos	Investigación avanzada / casos donde los carvers básicos fallan

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

El workflow correcto en la vida real:

¿Filesystem intacto?

— SÍ → fls / icat (The Sleuth Kit) → reconstruye archivo lógico → foremost sobre el archivo reconstruido

— NO → foremost -t jpg (primera pasada, encuentra lo contiguo)

— ¿Encontró la JPG completa? → ✓ Validar (abrir, EXIF, hash)

— ¿Truncada o corrupta? →

— scalpel con hints de tamaño

— Validador estructural de JPEG (verificar markers JPEG)

— Suite comercial (FTK/EnCase/X-Ways)

¿Cómo detectas que la imagen extraída está corrupta?

Prueba	Comando / Acción	Qué indica
Abrir en visor	eog 00000009.jpg o display	Si no se abre o tiene franjas → truncada/fragmentada
Verificar estructura	jpeginfo 00000009.jpg	Muestra si el footer FF D9 está presente y si los markers son válidos
Comparar tamaño	ls -la vs tamaño esperado	Si es mucho menor → truncada
Hash del extraído	sha1sum 00000009.jpg	No te dice si está corrupta, pero lo documentas para el informe

En el contexto de este laboratorio (steganografía en .doc)

En el caso de la captura, la JPG estaba embebida dentro de un archivo .doc, no fragmentada en el disco. Los bytes dentro del .doc están en orden secuencial. Por eso foremost la encontró completa en una sola pasada.

La fragmentación es un problema cuando:

→ Analizas una imagen de disco completa (.dd, .E01)

→ El archivo original estaba fragmentado en el filesystem

→ El filesystem está dañado y no puedes usar fls/icat

En la room de TryHackMe, este escenario no aparece (por diseño: es una introducción). Pero en un caso real de disco duro, es el problema número 1, que se va a encontrar.

Resumen en una frase

foremost es un lector lineal: copia bytes en orden hasta encontrar el footer. Si el archivo está fragmentado, lo que hay "entre" los fragmentos no es parte del archivo, pero foremost no lo sabe → copia basura → imagen corrupta.

Comparar tamaño: ¿cómo se hace exactamente?

Imaginemos que solo disponemos del documento y la imagen incrustada en el..

podemos proceder de la siguiente forma:

1. *audit.txt* vs *archivo en disco*

```
cat /tmp/peritaje_word/evidencias_extraidas/audit.txt
```

→ Size: 124 KB

```
ls -la /tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg
```

→ 126976 bytes (= 124 KB)

Si coinciden → la extracción fue completa (foremost copió exactamente lo que reportó).

Si no coinciden → error en la extracción (disco lleno, permisos, etc.).

```
(kali@kali)-[/tmp/peritaje_word/jpg]
$ cat /tmp/peritaje_word/audit.txt
Foremost version 1.5.7 by Jesse Kornblum, Kris Kendall, and Nick Mikus
Audit File

Foremost started at Fri Sep 18 16:17:44 2026
Invocation: foremost -t jpg -i ransom-letter.doc -o /tmp/peritaje_word/evidencias_extraidas
Output directory: /tmp/peritaje_word
Configuration file: /etc/foremost.conf

File: ransom-letter.doc
Start: Fri Sep 18 16:17:44 2026
Length: 149 KB (153088 bytes)

Num      Name (bs=512)      Size      File Offset  Comment
0:       00000009.jpg      124 KB           4839
Finish: Fri Sep 18 16:17:44 2026

1 FILES EXTRACTED

jpg:= 1

Foremost finished at Fri Sep 18 16:17:44 2026
```

```
(kali@kali)-[/tmp/peritaje_word/jpg]
$ ls -la /tmp/peritaje_word/jpg/00000009.jpg
-rw-rw-r-- 1 kali kali 127107 Sep 18 16:17 /tmp/peritaje_word/jpg/00000009.jpg
```

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Ahora la comparación real

Fuente	Valor	¿Qué es?
ls -la	127.107 bytes	Tamaño del archivo extraído en disco
audit.txt → Size	124 KB	Tamaño que reporta foremost
audit.txt → Length	149 KB (153.088 bytes)	NO es la JPG. Es el tamaño del .doc (el input)

¿124 KB = 127.107 bytes?

$124 \text{ KB} \times 1024 = 126.976 \text{ bytes}$

El archivo pesa 127.107 bytes. Diferencia: 131 bytes.

¿Es un problema? No. foremost redondea a KB en el audit. $127.107 \text{ bytes} = 124,1 \text{ KB} \rightarrow$ foremost lo muestra como "124 KB". Es la misma cosa. ✓

Lo que NO se debe comparar

"El audit dice 149 KB, mi archivo pesa 127.107 bytes → ¡no coincide!"

✗ Error. El 149 KB es el tamaño de ransom-letter.doc (el archivo que entró). La JPG que sale es más pequeña porque el .doc tiene además estructura OLE, texto, etc.

ransom-letter.doc (153.088 bytes)

[OLE + texto]	[JPG de 127.107 bytes]	[resto]	
~26 KB	~124 KB	~2 KB	

La regla simple

Compara	Con	¿Para qué?
ls -la (bytes)	audit.txt → Size (KB)	Verificar que la extracción fue completa
ls -la (bytes)	max_size de foremost.conf	Detectar truncamiento (si = max_size → truncado)
ls -la (bytes)	audit.txt → Length	✗ Nunca. Son archivos distintos (input vs output)

NubeServer

2. Tamaño vs max_size de foremost.conf

```
grep -A2 "jpg" /etc/foremost.conf
# → jpg y 20000000 \xff\xd8\xff\xe0\x00\x10 \xff\xd9
# jpg y 20000000 \xff\xd8\xff\xe1\xff\xd9
# jpg y 20000000 \xff\xd8\xff\xe2\xff\xd9
#           ↑
# max_size = 20.000.000 bytes (~20 MB)
```

La señal de alerta:

Tamaño extraído	Interpretación
124 KB ($\ll$ 20 MB)	✓ Foremost encontró el footer FF D9 antes del límite → archivo completo
~20 MB (= max_size)	Foremost no encontró el footer → cortó a los 20 MB → probablemente truncado

Eso es la comparación real. No necesitas el "tamaño original". Si el archivo extraído pesa exactamente 20.000.000 bytes, es una bandera roja.

En este caso: 127.107 bytes $\ll$ 20.000.000 bytes → ☒ No alcanzó el límite → footer encontrado → archivo completo.

3. Tamaño vs contexto (el "sentido común forense")

¿Es una foto de móvil? → Esperas 2-5 MB. Si te sale 124 KB → sospechoso.
¿Es un icono o thumbnail? → 50-200 KB es normal.
¿Es un screenshot? → Depende de la resolución, pero típicamente 100 KB - 2 MB.

Paso 3: ¿Alcanzó el max_size?

127107 < 20000000 → ✓ No alcanzó el límite → footer encontrado → completo

Esto no es una prueba técnica, es un indicio que se documenta en el informe: "El tamaño del archivo extraído (124 KB) es coherente con una imagen de baja resolución, pero no permite confirmar visualmente la integridad sin abrir el archivo."

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

Resumen: el flujo real

Paso 1: ¿Cuánto dice el audit?

```
grep "Size" /tmp/peritaje_word/evidencias_extraidas/audit.txt  
# → 124 KB
```

Paso 2: ¿Cuánto pesa el archivo real?

```
ls -la /tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg  
# → 126976 bytes → ✓ Coincide
```

Paso 3: ¿Alcanzó el max_size?

```
# 127107 < 20000000 → ✓ No alcanzó el límite → footer encontrado → completo
```

Paso 4: ¿Es una JPG válida?

```
file /tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg  
# → "JPEG image data, JFIF standard 1.01, aspect ratio, density 1x1" ✓
```

Si en el Paso 3 el tamaño fuera 200000 bytes exactos → truncado. Ahí es donde ls -la muestra la realidad

Si ya sé que está corrupta o no con file y ls-la, ¿para qué sirve el hash?

Respuesta directa: el SHA1 no es un diagnóstico. Es una prueba legal.

La distinción clave

Herramienta	Responde a la pregunta...	Analogía
file	"¿Es una JPG válida?"	"¿Es un documento médico?"
ls -la	"¿Pesa lo que debería?"	"¿Tiene las mismas páginas?"
sha1sum	"¿Es exactamente el mismo archivo que cuando lo extraje?"	"¿Es la misma copia que firmé hace 3 días?"

El SHA1 no dice si la imagen se ve bien. Dice: "estos 126.976 bytes, en este orden exacto, son idénticos a los que tenía el archivo en el momento X."

NubeServer

¿Cuándo lo usas? (el workflow real)

MOMENTO 1: Acabas de extraer con foremost

```
sha1sum /tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg  
# → a3f2c8... (lo anotas en tu informe)
```

MOMENTO 2: Haces tu análisis (abres, comparas, exiftool, etc.)

...pasan horas o días...

MOMENTO 3: Antes de entregar el informe al juez

```
sha1sum /tmp/peritaje_word/evidencias_extraidas/jpg/00000009.jpg  
# → a3f2c8... ✓ Mismo hash → no se modificó
```

Si el hash cambia entre momento 1 y 3 → algo (o alguien) tocó el archivo. Ya no puedes testificar que "lo que analicé es lo que extraje".

¿Qué NO detecta?

Situación	¿El SHA1 lo detecta?
Alguien reescribe 1 byte del archivo	✓ Sí (el hash cambia)
El archivo se corrompió durante la extracción (foremost copió mal)	✗ No. El hash se calcula sobre lo que ya está copiado. Si foremost copió basura, el hash de la basura es "válido"
La JPG está truncada (sin footer)	✗ No. El hash de un archivo truncado es un hash válido de ese archivo truncado

Por eso el SHA1 no sustituye a file ni a ls -la. Son complementarios:

file → ¿Es estructuralmente una JPG?
ls -la → ¿Pesa lo que el audit dice?
sha1sum → ¿Es la MISMA copia que documenté?

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

¿Por qué SHA1 y no MD5 o SHA256?

Hash	Bits	Velocidad	Uso forense actual
MD5	128	Rápido	✗ Obsoleto (colisiones demostradas)
SHA1	160	Rápido	Aceptado en la mayoría de jurisdicciones, pero SHA256 es preferible
SHA256	256	Ligeramente más lento	✓ Estándar actual

En la room indica SHA1 porque FTK Imager lo usa por defecto. En un caso real de 2026, se usaría SHA256 (o ambos).

En el informe forense, se documenta así:

EVIDENCIA: 00000009.jpg
TAMAÑO: 126.976 bytes
SHA256: 7a3f2c... (calculado en: 2026-09-10 18:16:02)
SHA256 VERIFICADO: 7a3f2c... (verificado en: 2026-09-12 09:00:15)
ESTADO: ÍNTEGRO (hashes coinciden)
ANALISTA: Nubeserver

Esa última línea —"hashes coinciden"—→ es lo que le permite al analista decir en el juicio:

"El archivo que analicé es byte a byte idéntico al que extraje de la evidencia original. No ha sido modificado en ningún momento."

Sin esa línea, la defensa dice: "¿Y si lo re-encodificaron? ¿Y si le quitaron metadata? No hay forma de saberlo."

Resumen en una frase

El SHA1 no diagnostica. Cadenas. Es el sello de cera digital: no te dice si la carta está bien escrita, te dice que nadie la abrió desde que la sellaste.

NubeServer

OTRAS PREGUNTAS A ANALIZAR:

En este apartado, se va a plasmar las preguntas que nos pueden surgir a lo largo de nuestra formación en ciberseguridad,

Numero	Pregunta	Por qué es interesante
1	Si foremost solo busca header y footer, ¿qué pasa si dos JPGs están uno detrás de otro sin separación?	Te obliga a entender los límites del carving
2	¿Por qué foremost no puede simplemente "saltar" los bytes que no coinciden con el formato JPEG para reconstruir un archivo fragmentado?	Porque la respuesta te enseña por qué el carving es limitado
3	Si la cadena de custodia es tan crítica, ¿por qué no es automática? ¿Por qué depende de que alguien firme un papel?	Te hace pensar en el diseño del sistema legal vs. técnico
4	¿Qué pasa si el write-blocker falla a mitad de la imagen? ¿Se pierde todo? ¿Se puede repetir?	Escenario real de laboratorio
5	¿Por qué FTK Imager usa SHA1 si ya se sabe que SHA1 es vulnerable a colisiones?	Diferencia entre "seguro criptográficamente" y "suficiente para forense"
6	Si la imagen forense es bit a bit, ¿por qué no puedo simplemente copiar y pegar el USB?	Parece obvio pero la respuesta no lo es
7	¿Qué diferencia hay entre un archivo "borrado" y un espacio "no asignado"?	Fundamento de por qué el carving funciona
8	¿Por qué el nombre del archivo extraído por foremost no es el original? ¿Se puede recuperar?	Conectado al caso: "00000009.jpg" no dice nada

HERRAMIENTAS DE VERIFICACIÓN DE IMAGENES EN KALI SIN INSTALAR NADA

Aunque para realizar esta práctica se ha instalado varias herramientas, a continuación se indican varias herramientas que nos hubiesen servido para nuestro beneficio.

Nivel 1: ¿Qué es? (sin abrir)

Comando	Qué te dice	Ejemplo
file 00000009.jpg	Tipo de archivo por magic bytes	JPEG image data, JFIF standard 1.01
ls -la 00000009.jpg	Tamaño en bytes	127107
xxd 00000009.jpg head -1	Primeros bytes en hex	ffd8ffe0 00104a46... → confirma header JPG
xxd 00000009.jpg tail -1	Últimos bytes en hex	...003fffd9 → confirma footer JPG

¿Por qué xxd? Porque te deja ver con tus propios ojos que el archivo empieza con FF D8 FF y termina con FF D9. No confías en file, lo verificas a nivel byte. Es lo más cercano a "abrir la caja y mirar dentro" sin alterarla.

Nivel 2: ¿Qué dimensiones / formato exacto?

Comando	Qué te dice	Ejemplo
identify 00000009.jpg	Formato, dimensiones, profundidad, tipo de color	00000009.jpg JPEG 800x600 8-bit sRGB
identify -verbose 00000009.jpg	Todo lo anterior + metadata EXIF si existe	Muestra cámara, fecha, etc.

identify viene con ImageMagick, que está en Kali por defecto. No necesitas instalar nada.

¿Por qué identify y no display?

identify → no abre ventana, solo te da datos. Más rápido, más forense (no altera nada, no genera logs de "imagen abierta").

display → abre una ventana gráfica. Útil para ver visualmente si la imagen tiene franjas o está corrupta.

Nivel 3: ¿Se ve bien? (verificación visual)

Comando	Qué hace
display 00000009.jpg	Abre ventana con la imagen (ImageMagick)
xdg-open 00000009.jpg	Abre con el visor por defecto de XFCE (Ristretto)
Doble clic en Thunar	Mismo que xdg-open

En un laboratorio real: usas display o xdg-open para verificar visualmente, pero documentas que lo hiciste. No es un paso "destrutivo", pero en un caso judicial, cada interacción con la evidencia se registra.

Nivel 4: ¿Qué hay dentro a nivel binario?

Comando	Qué te dice
strings 00000009.jpg	Texto legible embebido (EXIF, nombres, URLs)
xxd 00000009.jpg grep -i "exif"	Busca el segmento EXIF en el binario
hexdump -C 00000009.jpg head -20	Dump hex con vista ASCII

¿Cuándo lo usas? Cuando file dice "JPEG" pero sospechas que hay algo más embebido (otra imagen, texto, steganografía). strings te muestra cualquier texto ASCII/UTF-8 que esté dentro.

Nivel 5: Integridad (hash)

Comando	Qué te dice
sha1sum 00000009.jpg	Hash SHA1
sha256sum 00000009.jpg	Hash SHA256 (preferible en 2026)

Práctica 4: INTRODUCCIÓN AL FORENSE DIGITAL

NubeServer

El workflow completo (todo sin instalar nada)

1. ¿Qué es?

```
file /tmp/peritaje_word/jpg/00000009.jpg
```

2. ¿Cuánto pesa?

```
ls -la /tmp/peritaje_word/jpg/00000009.jpg
```

3. ¿Header y footer correctos?

```
xxd /tmp/peritaje_word/jpg/00000009.jpg | head -1
```

```
xxd /tmp/peritaje_word/jpg/00000009.jpg | tail -1
```

4. ¿Dimensiones y formato?

```
identify /tmp/peritaje_word/jpg/00000009.jpg
```

5. ¿Se ve bien?

```
display /tmp/peritaje_word/jpg/00000009.jpg
```

6. ¿Texto embebido?

```
strings /tmp/peritaje_word/jpg/00000009.jpg
```

7. ¿Hash para el informe?

```
sha256sum /tmp/peritaje_word/jpg/00000009.jpg
```

7 comandos. Cero instalaciones. Verificación completa.

¿Qué NO tienes (y no necesitas para esta práctica)?

Herramienta	Para qué sirve	¿Necesario aquí?
exiftool	Extraer/editar metadata EXIF en profundidad	✗ No. identify -verbose basta
exifprobe	Estructura interna de JPEG (segments, IFDs)	✗ No. Solo para investigación avanzada
jpeginfo	Validar estructura JPEG marker a marker	✗ No. xxd + file basta
binwalk	Extraer archivos embebidos en firmwares	✗ No. foremost ya lo hizo

NubeServer

5. ORIENTACIÓN DE LA INFORMATICA FORENSE Y LÍNEA DE DESARROLLO

La disciplina aplicada en este caso no corresponde a la ingeniería inversa de malware o análisis de red, sino a la Forense de Medios y Análisis de Artefactos de Usuario (Media & Artifact Forensics). La línea de desarrollo forense se rige por un flujo metodológico estricto:

⬇️ Adquisición de Evidencias (Preservación de Metadatos de Sistema)



Cadena de Custodia (Generación de Firmas Criptográficas)



🔗 Análisis Estructural de Bloques (File Carving de Contenedores OLE/ZIP)



🔍 Extracción de Metadatos de Aplicación (EXIF / XMP / Estructuras PDF)



🔍 Perfilado y Atribución (Traducción de Datos Técnicos a Evidencias Legales)